

Protection de la donnée au repos (BitLocker)

1. Concepts de protection de la donnée au repos

La protection de la donnée au repos (Data at Rest) vise à empêcher l'accès aux données stockées sur un support physique en cas de vol, de perte ou de compromission de l'hyperviseur (vol de fichier disque virtuel, ex: .vmdk ou .vhdx).

Sous Windows, le composant natif assurant le chiffrement intégral du disque (FDE - Full Disk Encryption) est BitLocker. Il s'agit de l'équivalent fonctionnel de LUKS sous Linux. BitLocker chiffre l'intégralité du volume au niveau des secteurs matériels, rendant le système d'exploitation et les données illisibles sans la clé de déchiffrement.

2. Architecture de chiffrement BitLocker

BitLocker utilise un système de clés en cascade pour protéger les données. La clé symétrique qui chiffre réellement les données sur le disque est la clé FVEK (Full Volume Encryption Key). Cette clé est elle-même chiffrée par une clé maître de volume, la VMK (Volume Master Key).

La sécurité de BitLocker repose sur la manière dont la VMK est protégée (ou "scellée").

2.1 Le module TPM (Trusted Platform Module)

Le TPM est une puce cryptographique matérielle présente sur la carte mère (ou émulée par l'hyperviseur via vTPM). BitLocker utilise le TPM pour stocker la VMK de manière sécurisée.

Le TPM utilise des registres de configuration de plateforme (PCR - Platform Configuration Registers) pour vérifier l'intégrité de la séquence de démarrage.

- **PCR 0, 2, 4, 11** : Mesurent le BIOS/UEFI, la table de partition, le chargeur de démarrage (Bootmgr).
- **PCR 7** : Mesure l'état du Secure Boot.

Au démarrage, le TPM compare l'état actuel du matériel avec l'état enregistré lors de l'activation de BitLocker. Si la séquence de démarrage est identique (aucun composant matériel ou logiciel de boot n'a été altéré), le TPM libère la VMK et le système démarre de manière transparente.

Si une modification est détectée (ex: démarrage sur une clé USB, modification du BIOS), le TPM refuse de libérer la clé et le système bascule en mode de récupération.

2.2 Modes de déverrouillage (Protecteurs)

Selon le niveau de sécurité requis, BitLocker peut être configuré avec différents protecteurs :

- **TPM seul** : Le déverrouillage est transparent pour l'utilisateur. Protège contre le vol du disque dur, mais pas contre le vol de la machine complète.
- **TPM + Code PIN** : Exige une intervention humaine au démarrage. Recommandé par l'ANSSI pour les postes nomades.
- **TPM + Clé de démarrage (USB)** : La clé de déverrouillage est physiquement séparée de la machine.
- **Mot de passe / Clé USB (Sans TPM)** : Utilisé sur des systèmes matériels ou virtuels ne disposant pas de puce TPM. Le chiffrement est purement logiciel et l'utilisateur doit saisir un mot de passe à chaque démarrage.

3. Centralisation et récupération (Active Directory)

Le risque principal d'un déploiement BitLocker est la perte de données suite à une défaillance matérielle (carte mère hors service) ou à un oubli de code PIN.

Il est nécessaire de configurer une clé de récupération (Recovery Password), composée de 48 chiffres.

Dans un environnement d'entreprise, cette clé ne doit pas être laissée à la gestion de l'utilisateur. BitLocker s'intègre nativement à Active Directory Domain Services (AD DS).

Par le biais des Stratégies de Groupe (GPO), il est possible de forcer le système à :

1. Générer une clé de récupération à 48 chiffres.
2. Sauvegarder cette clé dans un attribut de l'objet Ordinateur dans l'Active Directory.
3. Interdire le début du processus de chiffrement tant que la clé n'a pas été confirmée comme correctement enregistrée sur le Contrôleur de Domaine.

4. Considérations pour les environnements virtuels

Dans un environnement virtualisé (VMware, Hyper-V, Proxmox), l'activation de BitLocker nécessite certaines configurations spécifiques :

- L'hyperviseur doit supporter et exposer un composant vTPM à la machine virtuelle.
- Si le vTPM n'est pas disponible, il est possible de modifier les stratégies locales de Windows pour autoriser l'utilisation de BitLocker sans module de plateforme sécurisée compatible. Cette configuration requiert obligatoirement la saisie d'un mot de passe ou l'insertion d'une clé virtuelle au démarrage de l'OS.